

PNK Suguan 1.0.1 — First-Run Administrator Guide

PNK Suguan 1.0.1 — release documentation (source: FIRST-RUN-ADMINISTRATOR-GUIDE.md)

This guide covers the initial administrator account: how it is created, where its one-time password comes from, what you must do with it, and how the everyday **Administrator** role differs from the exceptional **Super Admin** capability.

This document contains no credentials, and there are none to leak. No password or secret is packaged in the installer for any account. The only secret that exists at first run is generated on your machine at first run, and it is written to your own data folder.

1. The default administrator

Item	Value
E-mail (default)	admin@pnk.local
Password	None is preset. A one-time password is generated on first run (section 2)
Display name	Initial Administrator
Role	Administrator (ADMIN) — *not* Super Admin
Password state	Must be changed at first sign-in

The e-mail address is a default, not a security boundary

admin@pnk.local is a convenient local identity written into your data folder as INITIAL_ADMIN_EMAIL on first run. It is a **value, not an authorization rule** — permissions come from roles, never from the address. If you prefer a different address, set it **before the first start** by editing that line in %LOCALAPPDATA%\PNK Suguan\.env, then start PNK Suguan.

It is also not a real mailbox. Nothing is sent to it, and it cannot receive mail.

Where it is written

```
%LOCALAPPDATA%\PNK Suguan\.env
```

The first line you care about is INITIAL_ADMIN_EMAIL. The same file also holds the machine-generated secrets (database password, unlock secret, OTP pepper). **Treat that whole file as secret material** and never copy it into the program folder, e-mail it, or share it — it is machine-specific.

2. How the one-time password is generated

The launcher generates the password **on your machine, at the moment of first run**:

- **20 characters**, produced with the operating system's cryptographically secure random generator;
- guaranteed to contain at least one uppercase letter, one lowercase letter, one digit and one symbol;
- built from a character set with easy-to-confuse glyphs removed (no I, L, 0, O, 1), so it can

be read aloud and retyped reliably;

- shuffled with the same secure generator, so the required characters are not in predictable positions.

It is handed to the account-creation step through a temporary file inside the data folder's run directory, which is deleted immediately afterwards, and it is **never** written to a log, printed in the console, or left in the process environment.

Where you read it

```
%LOCALAPPDATA%\PNK Suguan\FIRST-RUN-ADMIN-PASSWORD.txt
```

It is created only when the administrator is provisioned — that is, on a genuine first run. It records the e-mail address and the one-time password, and it tells you to change the password and delete the file. The launcher's startup output points you to this file by **path only**.

3. What you must do at first sign-in

1. Start PNK Suguan if it is not already running; your browser opens on the application.
2. Sign in with the e-mail address and the one-time password from

`FIRST-RUN-ADMIN-PASSWORD.txt`.

1. You are taken to a **change-password** screen and **cannot navigate anywhere else** until the change is complete. The account is created flagged as `must change password`, and that flag is enforced server-side — it is not merely a suggestion in the interface.

1. Choose a new password that satisfies the policy in section 4.
2. **Delete `FIRST-RUN-ADMIN-PASSWORD.txt`**. It has served its purpose, and it is a live credential sitting in plain text.

Changing the password **revokes every session for that account**, including the one you are using. You will be asked to sign in again with the new password — that is expected, and it is the reason a browser that was already open cannot quietly continue using the old access.

If the file is still present on later launches, the launcher reminds you that it exists and asks you to delete it once you no longer need it. (It only ever generates a **new** administrator when the account table is empty — the existence of an old file never becomes a credential.)

4. Password policy

Enforced for every password set through the application — the initial rotation, later changes, and passwords you set for other users:

- at least **10 characters**;
- contains an **uppercase** letter;
- contains a **lowercase** letter;
- contains a **digit**;
- contains a **symbol** (any character that is not a letter or digit).

A password that does not satisfy all five is rejected, and the interface lists exactly which requirement failed. The generated first-run password satisfies the policy by construction.

5. Administrator responsibilities

The **Administrator** role is the day-to-day full-function role. In practice it is responsible for:

- **Master data** — maintaining teachers (including each teacher's language) and dako records, and enabling or disabling a dako.
- **User accounts** — creating users, assigning one of the three assignable roles

(**Administrator**, **Scheduler/Encoder**, **Viewer**), resetting a user's password (which issues a new temporary password and re-forces rotation), and deactivating accounts.

- **Scheduling** — generating a DRAFT schedule, encoding weekly assignments, finalizing a week, and publishing a finalized week.
- **Availability** — maintaining weekly availability, including the current and next week independently.
- **Corrections and audit** — revising a FINALIZED week through the authorized correction window (with a reason), and consulting the audit log.

An Administrator can also override certain **hard** scheduling rules by supplying a reason, which is recorded. Two rules are **not** in that category, and no role can override them:

- **`LANGUAGE\_MISMATCH`** — a Filipino teacher can never be placed on an English dako.
- **`DAKO\_DISABLED`** — a disabled dako cannot receive assignments.

The only remedy for LANGUAGE_MISMATCH is to correct the teacher's profile language.

The complete permission list is in USER-ROLE-GUIDE.pdf.

6. Administrator vs Super Admin

These are different things, and it matters which one you are using.

	Administrator (ADMIN)	Super Admin (SUPER_ADMIN)
Created automatically at first run	Yes (the account in section 1)	No — never
Can be granted from the Users interface	Yes	No. Create/Edit User offers Administrator, Scheduler/Encoder and Viewer only
Day-to-day administration	Yes — this is the role	No more than an Administrator
Revise a FINALIZED week	Yes	Yes
Correct a PUBLISHED week	No	Yes — this is the only capability that distinguishes it

Super Admin is an exceptional emergency role. It exists for one purpose: correcting a week that has already been published. It is not a "higher administrator" for routine work, and it is deliberately not provisioned by the application — an operator creates it deliberately against the database, outside the UI, so that a mistake in the Users page can never mint one.

The published-week correction it authorizes is tightly bounded:

- **Super Admin only** — every other role, Administrator included, is refused;
- **temporary** — the correction window is time-boxed (default 30 minutes) and closes by itself;
- **reason required** — a correction cannot be performed without a stated reason;
- **scoped** — the window applies to one week, and to the account that opened it;
- **status-preserving** — correcting a published week does not downgrade its status; the week does not

revert to DRAFT, and no global unlock occurs;

- **audited** — opening, using and closing the window are recorded;
- **fail-closed** — it requires a secret held only in your data folder

(PNK_SUPER_ADMIN_SECRET). If that secret is absent, the published-correction path refuses every request rather than falling open.

Opening the PUBLISHED correction window also requires the Super Admin unlock secret to be presented alongside the account's normal authentication. Because that secret lives in %LOCALAPPDATA%\PNK Suguan\.env, protecting that file is what protects this capability.

7. Account recovery

Two paths exist. Neither is an offline substitute for a password.

1. **Self-service ("Forgot password")** — sends a one-time code by e-mail. This requires SMTP to be configured by an operator in the data folder's `.env` (PNK_SMTP_* keys). **SMTP settings are operator-provided information** — they are not part of the release, and the flow cannot deliver mail without them. Codes are single-use, expire, and lock out after five attempts.

1. **Operator reset** — an operator with access to the machine can reset an account directly, using the provisioning tools that ship with the source (not with the installer). This is the documented escape hatch when SMTP is unavailable.

There is deliberately **no insecure offline password-reset shortcut** in the application, and none was added for this release.

Session behaviour you should expect: sessions last 12 hours, are invalidated by logout, are all revoked when the account's password changes, and are re-verified against the database on every request. Deactivating a user immediately ends their access.

8. Everyday hygiene

- Delete `FIRST-RUN-ADMIN-PASSWORD.txt` as soon as you have signed in and rotated the password.
- Never copy `%LOCALAPPDATA%\PNK_Suguan\.env` anywhere. It holds live secrets for this machine.
- Give people the smallest role that lets them do their work — most encoders need

Scheduler/Encoder, and reviewers usually need only Viewer.

- Do not share accounts. Each user gets their own, so the audit trail means something.
- Treat the ability to open a PUBLISHED correction window as a break-glass action: it is audited, and it

should be used only when a published week genuinely must be corrected.

For routine operation see `OPERATIONS-GUIDE.pdf`; for problems see `TROUBLESHOOTING.pdf`.